Phát hiện botnet IoT bằng autoencoder nhẹ

Đề tài DT043 · Bài giữa kỳ An toàn Bảo mật Hệ thống thông tin

Hoàng Thanh Trà · MSSV 1150080120 · Lớp 11CNPM2

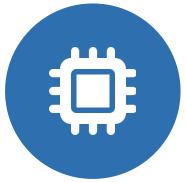
Per-device AE · lượng tử hóa int8 · edge benchmark · MTD lai · tái lập 3-layer THARM

Bài toán: phát hiện botnet ngay tại edge



Thiết bị IoT dễ bị chiếm

Mật khẩu mặc định, ít vá – Mirai, BASHLITE chiếm hàng loạt để DDoS



Edge có tài nguyên hạn chế

Bộ phát hiện phải nhỏ (KB), nhanh (µs), ít RAM và năng lượng



Mỗi thiết bị một hành vi

Học benign riêng từng thiết bị, cảnh báo khi lỗi tái tạo tăng

Câu hỏi nghiên cứu

- RQ1 Tái lập baseline Meidan 2018
- RQ2 Per-device có hơn model chung?
- RQ3 AE nhẹ giữ chất lượng?
- RQ4 int8 + hiệu chỉnh ngưỡng
- RQ5 Chạy được trên edge?
- RQ6 AE kích hoạt MTD lai

Tiêu chí thành công chốt trước khi chạy (SHA-256 ghi trong nhật ký)

Paper chính nói về MTD → chiến lược hai track

Masud et al. (2025, Computers & Security 153:104380) – hybrid Moving Target Defence trên mô hình 3-layer THARM; không dùng autoencoder, N-BaIoT hay edge.

Track A · phát hiện

- Per-device AE trên N-BaIoT, baseline Meidan 2018
- Model nhẹ + int8 + hiệu chỉnh ngưỡng
- Edge benchmark trên 1 lõi E-core

Track B · MTD

- Tái lập 3-layer THARM bằng đúng CVE/topology của paper (E11)
- Shuffle / diversity / redundancy và tổ hợp
- MTD lai: cảnh báo AE kích hoạt move

Cầu nối: cửa sổ cảnh báo của AE (Track A) là sự kiện kích hoạt MTD event-based (Track B)

Dữ liệu N-BaIoT và chống rò rỉ train/test

7.06M

dòng · UCI, CC BY 4.0 · 107 file khớp SHA-256

157,779

dòng trùng lặp bị loại (2.2%)

5.5–61.8×

attack nhiều hơn benign → dùng macro-F1, FPR

DStrn · train AE + fit scaler

DSopt · ngưỡng tr*, cửa sổ ws*

Test benign + mọi tấn công

← chia benign theo thời gian 1/3 · 1/3 · 1/3; khoảng trắng giữa các khối = 500 dòng đệm bị bỏ →

- Khử trùng lặp trong từng file; loại dòng test trùng hash với train
- Scaler fit chỉ trên DStrn; ngưỡng/cửa sổ chỉ từ DSopt
- Đối chứng E6 cố tình chia ngẫu nhiên: FPR "đẹp giả" 0.0006 so với 0.0025

Pipeline, mô hình so sánh và hệ thống 4 tầng



Mô hình	Kiến trúc	Tham số
B0 Meidan	115-86-58-38-29-…	36,876
B1 chung	B0 dùng chung 9 thiết bị	36,876
B2	Isolation Forest	–
V1 nhẹ	115-32-8-32-115	8,059

AI
huấn luyện, int8, xuất gói có SHA-256

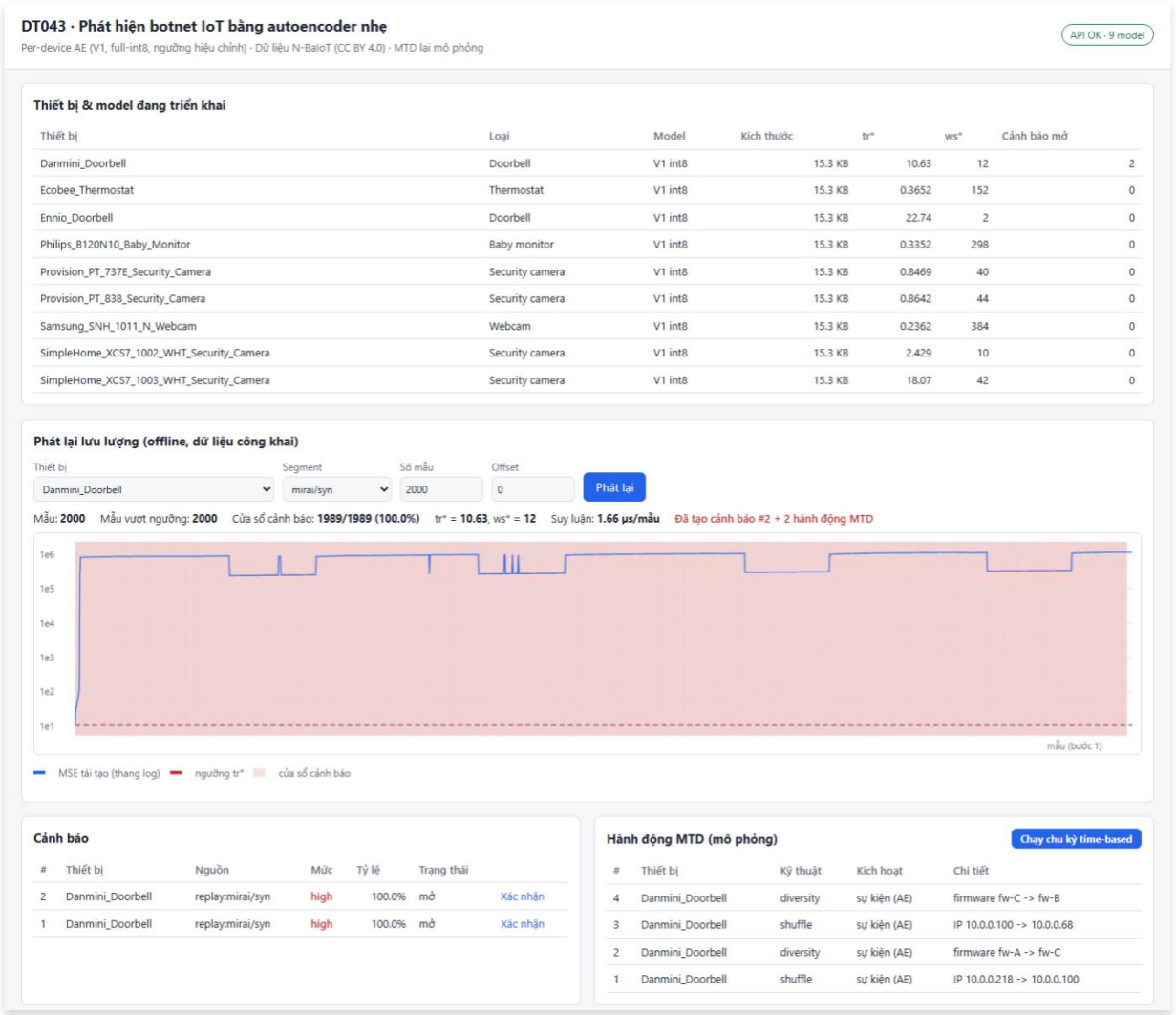
Backend
FastAPI, TFLite 1 luồng, từ chối gói bị sửa

Database
SQLite: cảnh báo, hành động MTD

Frontend
dashboard phát lại, biểu đồ MSE

54 test tự động: unit · integration · negative (gói bị sửa 1 byte, path traversal, sai số chiều)

Demo: phát hiện + cảnh báo + MTD trên dashboard



DT043 · Phát hiện botnet IoT bằng autoencoder nhẹ

Per-device AE (V1, full-int8, ngưỡng hiệu chỉnh) · Dữ liệu N-BaIoT (CC BY 4.0) · MTD lai mô phỏng

API OK · 9 model

Thiết bị & model đang triển khai

Thiết bị	Loại	Model	Kích thước	tr*	ws*	Cảnh báo mở
Danmini_Doorbell	Doorbell	V1 int8	15.3 KB	10.63	12	2
Ecobee_Thermostat	Thermostat	V1 int8	15.3 KB	0.3652	152	0
Ennio_Doorbell	Doorbell	V1 int8	15.3 KB	22.74	2	0
Philips_B120N10_Baby_Monitor	Baby monitor	V1 int8	15.3 KB	0.3352	298	0
Provision_PT_737E_Security_Camera	Security camera	V1 int8	15.3 KB	0.8469	40	0
Provision_PT_838_Security_Camera	Security camera	V1 int8	15.3 KB	0.8642	44	0
Samsung_SNH_1011_N_Webcam	Webcam	V1 int8	15.3 KB	0.2362	384	0
SimpleHome_XCS7_1002_WHT_Security_Camera	Security camera	V1 int8	15.3 KB	2.429	10	0
SimpleHome_XCS7_1003_WHT_Security_Camera	Security camera	V1 int8	15.3 KB	18.07	42	0

Phát lại lưu lượng (offline, dữ liệu công khai)

Thiết bị: Danmini_Doorbell · Segment: mirai/syn · Số mẫu: 2000 · Offset: 0 · Phát lại

Mẫu: **2000** Mẫu vượt ngưỡng: **2000** Cửa sổ cảnh báo: **1989/1989 (100.0%)** tr* = **10.63**, ws* = **12** Suy luận: **1.66 µs/mẫu** Đã tạo cảnh báo #2 + 2 hành động MTD

Cảnh báo

#	Thiết bị	Nguồn	Mức	Tỷ lệ	Trạng thái	
2	Danmini_Doorbell	replay:mirai/syn	high	100.0%	mở	Xác nhận
1	Danmini_Doorbell	replay:mirai/syn	high	100.0%	mở	Xác nhận

Hành động MTD (mô phỏng) — Chạy chu kỳ time-based

#	Thiết bị	Kỹ thuật	Kích hoạt	Chi tiết
4	Danmini_Doorbell	diversity	sự kiện (AE)	firmware fw-C -> fw-B
3	Danmini_Doorbell	shuffle	sự kiện (AE)	IP 10.0.0.100 -> 10.0.0.68
2	Danmini_Doorbell	diversity	sự kiện (AE)	firmware fw-A -> fw-C
1	Danmini_Doorbell	shuffle	sự kiện (AE)	IP 10.0.0.218 -> 10.0.0.100

mirai/syn (Danmini)

1989/1989 cửa sổ cảnh báo → cảnh báo high + shuffle IP + đổi firmware

benign (Ennio, phần test)

0 cảnh báo – không báo động giả

gafgyt/tcp (Ennio)

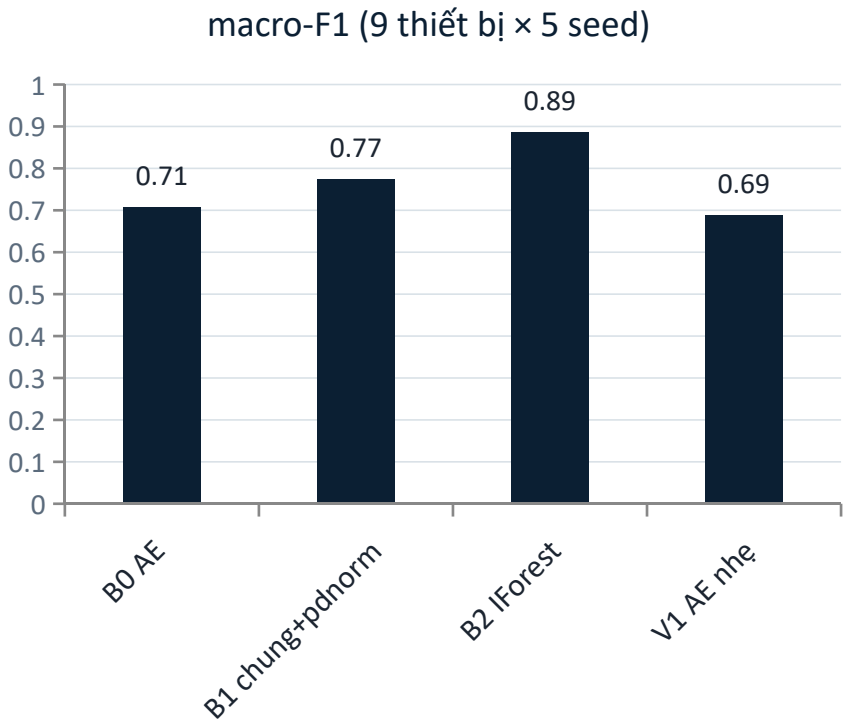
0 cảnh báo – đúng lỗi bỏ sót đã phân tích

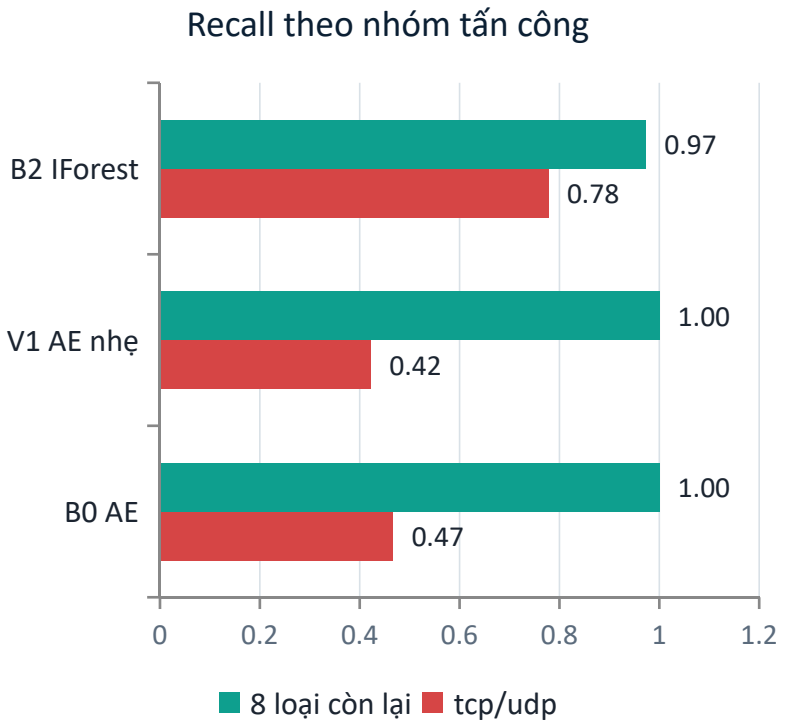
MTD time-based

Lưới an toàn cho tấn công AE bỏ sót

Chạy: uvicorn backend.app.main:app → http://127.0.0.1:8000/

Kết quả: FPR rất thấp, lỗi tập trung ở flood tcp/udp





0.0025

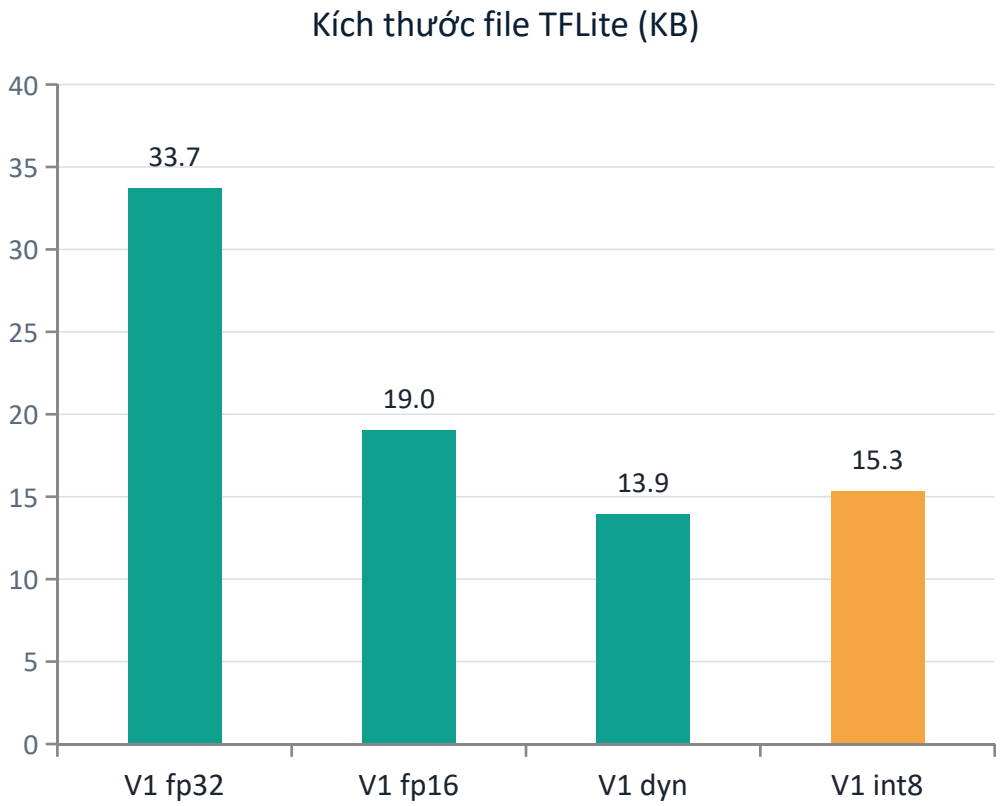
FPR của B0 (Meidan: 0.007)

0.822

TPR của B0 (Meidan: 100%)

Nguồn bị giả mạo liên tục → mỗi gói như "luồng mới" (weight = 1, variance = 0), MSE nằm dưới ngưỡng mean+std. Tám loại tấn công còn lại recall ≈ 1.0.

Lượng tử hóa int8 và edge benchmark



10.8 µs

p95 / mẫu (tiêu chí ≤ 1000 µs)

15.3 KB

model (tiêu chí ≤ 50 KB)

4.6 MB

RAM tăng thêm

102,899

mẫu/giây trên 1 lõi E-core

Hiệu chỉnh ngưỡng trên DSopt bằng chính model int8: FPR 0.0030 → 0.0016, cửa sổ 153 → 113 mẫu. Energy proxy ≈ 40.5 µJ/mẫu. RQ5 đạt với biên rất lớn.

MTD: tái lập paper chính bằng đúng dữ liệu của paper

Rủi ro	Paper	Tái lập
R_V5 (Windows 11)	12.58	12.578
R_V7 · R_V8	8.67 · 5.62	8.667 · 5.625
Đường shuffle	43.15	42.81 (-0.8%)
Đường diversity	43.31	42.97 (-0.8%)
Đường redundancy	43.31	42.97 (-0.8%)

HARM rút gọn (chu kỳ 20): ASP không MTD 0.498 → shuffle 0.409 · diversity 0.437 · kết hợp 0.327. MTD lai dùng cảnh báo AE: cùng chi phí, lộ diện ít hơn time-based.

6/7

kết luận tái lập được (topology Hình 3)

3/7

nếu dùng đúng Definition 2

Khớp: rủi ro mức VM ±0.01, đường tấn công −0.8%. Không khớp: tổng toàn mạng – paper cắt danh sách cạnh, công thức in mâu thuẫn; kết luận "S+D tốt nhất" phụ thuộc cạnh V6 → V4.

Dữ liệu paper: 18 CVE OS + 14 CVE dịch vụ (Bảng 1–2), 8 VM, Definition 2; shuffle/diversity/redundancy theo mục 4.2–4.4

Đối chiếu tiêu chí và kết luận

RQ	Giá trị đo	Kết luận
RQ1	TPR=0.8222, FPR=0.0025	**Không đạt**
RQ2	thắng 4/9, p=0.2852	**Không đạt**
RQ3	tham số 21.9%, Δ=+0.0171	**Không đạt**
RQ4	Δ=-0.0278, kích thước 45.5%	**Không đạt**
RQ5	p95=10.8 µs, 15.3 KB, ΔRSS=4.6 MB	**Đạt**

Không chỉnh tiêu chí sau khi có kết quả; báo cáo đủ 468 lần chạy.

- AE per-device bắt gần tuyệt đối 8/10 loại tấn công, FPR rất thấp; bỏ sót flood tcp/udp giả mạo nguồn
- V1 int8 15 KB, ~10 µs/mẫu trên 1 lõi – khả thi cho edge
- Kết quả dao động theo seed → cần nhiều lần chạy và kiểm định
- Tái lập paper chính: khớp mức VM/đường, 6/7 kết luận định tính
- Tiếp theo: đặc trưng cho flood giả mạo · Raspberry Pi + đo điện thật